

EGR6301 — Етичний хакінг

Лабораторна робота 6: Оцінка поверхні атаки невідомої цілі

Kioptrix Level 1.2 — Від розвідки до плану атаки без пострілу

Факультет комп'ютерних технологій та кібербезпеки • Весна 2026

Тривалість:	100 хвилин
Всього:	100 балів
Цільова машина:	Kioptrix Level 1.2 (Level 3) — VulnHub
Download:	https://www.vulnhub.com/entry/kioptrix-level-12-3,24/
Тип роботи:	Оцінка поверхні атаки без експлуатації (assessment-only)

ОБОВ'ЯЗКОВІ ПРАВИЛА ЗВІТУВАННЯ

Ця лабораторна робота не передбачає експлуатації. Ваше завдання — зібрати дані, знайти вразливості та обґрунтувати план атаки. Жодного reverse shell, жодного запуску експлойтів, жодних скріншотів root-доступу. Будь-який скріншот запущеного експлойта або отриманої оболонки в основному звіті означає НУЛЬ балів за Частину 4. Мета — навчитися мислити як пентестер ще до того, як палець ляже на кнопку "exploit".

Якщо ваш звіт містить лише вивід інструментів і скріншоти без вашого власного аналізу, ви отримаєте НУЛЬ балів за цей розділ. Кожен скріншот має супроводжуватися абзацом: ЩО ви знайшли, ЧОМУ це важливо, ЩО це означає для плану атаки.

Ви ПОВИННІ задокументувати щонайменше одну реальну невдачу: скан без результатів, інструмент з помилкою, сервіс без відповіді, гіпотезу, яка виявилася хибною. Опишіть що сталося, чому, і що ви зробили замість. Звіт без невдач — це звіт не з реального досвіду.

Кожен студент повинен написати унікальне обґрунтування ранжування векторів атаки власними словами. Двоє студентів можуть знайти однакові CVE, але жодні двоє не повинні описувати, чому один вектор переважає інший, ідентично. Ранжування — це професійне судження, а не копіювання з Exploit-DB.

Сценарій

Регіональна страхова компанія готується до планового аудиту інформаційної безпеки. За два тижні до початку повного тестування на проникнення вас запросили провести попередню оцінку поверхні атаки одного з серверів, розміщених у DMZ. Сервер працює давно. Ніхто з чинного IT-персоналу не пам'ятає, хто його налаштовував. Правила проведення тестування (Rules of Engagement) на цьому етапі категоричні: дозволено лише пасивну та активну розвідку, перелік сервісів, зіставлення з відомими вразливостями та аналіз. Експлуатацію заборонено до офіційного схвалення керівництвом клієнта, яке відбудеться лише після того, як ви подасте документ про поверхню атаки.

Це типовий сценарій у регульованих галузях. Клієнт хоче знати, що ви знайдете, перш ніж дозволити вам щось ламати. Ваш звіт стане підставою для затвердження обсягу наступної фази. Якщо ви правильно оціните та обґрунтуєте вектори, керівництво розширить scope. Якщо ні, можуть скасувати весь проєкт. Сервер представлений як VM Kioptrix Level 1.2 (також відома як Level 3), яку ви розгорнете у VirtualBox поряд із вашою атакуючою машиною Kali Linux.

Нагадування для тих, хто вже працював із Kioptrix Level 1 на Лабораторній 5: це інша машина. Інший набір сервісів, інша епоха Linux, інший веб-стек. Не припускайте, що ви побачите Apache 1.3 або Samba 2.2. Починайте з нуля. Все, чого ви навчилися на тижнях 1–5 — Nmap, Netcat, ручна взаємодія з сервісами, Nikto, NSE-скрипти, перелік SMB тепер потрібно застосувати у форматі професійного аналізу, а не як серію інструментів.

Рівні складності

Усі чотири частини обов'язкові для всіх студентів. На відміну від Лабораторної 5, Частина 4 більше не є додатковою; оцінка поверхні атаки без кульмінаційного аналізу векторів є неповною. Просунутим студентам, які виконали основну роботу швидко і хочуть перевірити свої висновки, пропонується необов'язковий Додаток А (див. кінець документа), який дозволяє верифікувати ОДИН вектор у контрольований спосіб. Додаток А не оцінюється і ніяк не впливає на бали.

Част.	Опис	Бали	Час
1	Розгортання цілі та початкова розвідка	25	~20 хв
2	Глибокий перелік сервісів (web, SMB, SSH)	25	~30 хв
3	Ідентифікація CVE та побудова карти вразливостей	25	~25 хв
4	Ранжування векторів атаки та обґрунтування	25	~25 хв

Частина 1: Розгортання цілі та початкова розвідка

(25 балів, приблизно 20 хвилин)

Реальна оцінка починається з найменшої кількості припущень. Ви маєте IP-діапазон і ціль, яку ніхто не пам'ятає. Вашим завданням є повернути з цього початкового запуску структурований набір фактів, на який можна буде спиратися у наступних частинах.

Завдання 1.1 — Розгортання VM (5 балів)

Завантажте образ VM Kioptrix Level 1.2 з VulnHub (або інструктор надасть його на USB-носії). Імпортуйте у VirtualBox. Налаштуйте мережевий адаптер на ту саму Host-Only мережу, що й у вашій Kali VM. Завантажте обидві машини. Перевірте зв'язність командою ping. Зверніть увагу, що Kioptrix 1.2 іноді не показує запрошення до входу одразу після завантаження; це очікувана поведінка, продовжуйте.

Зробіть скріншот, який підтверджує успішний ping з Kali на IP-адресу Kioptrix. Якщо IP не очевидна, використовуйте netdiscover або arp-scan у підмережі Host-Only.

Завдання 1.2 — Початкова розвідка Nmap (10 балів)

Виконайте комплексне сканування. Вам потрібно повернути: список усіх відкритих TCP-портів у діапазоні 1–65535, сервіс на кожному, версію сервісу там, де вона визначається, припущення про OS. Обирайте прапори сканування, свідомо не копіюйте команду з Lab 5 безпідставно. Якщо ви використовуєте швидке -F сканування, ви можете пропустити порти, які мають значення для цієї машини. Документуйте свій вибір прапорів у звіті.

Складіть таблицю сервісів зі стовпцями: Порт, Протокол, Стан, Сервіс, Версія, Нотатки. У стовпці "Нотатки" запишіть будь-що, що привернуло увагу: незвичайний банер, дивна версія, порт, якого ви не очікували побачити. Таблиця має містити щонайменше 4 сервіси.

Завдання 1.3 — Робочі гіпотези (10 балів)

Під таблицею напишіть абзац (5–7 речень) з трьома робочими гіпотезами про цю систему: яка це епоха Linux-дистрибутива на ваш погляд, яка ймовірна роль сервера у мережі компанії (веб-застосунок, файловий сервер, DNS, інше), і який сервіс ви вважаєте найбільш вірогідним початковим вектором. Це не остаточні висновки: це гіпотези, які ви перевіряєте у частині 2. Гарна гіпотеза вказує, яким саме доказом її можна спростувати.

Частина 2: Глибокий перелік сервісів

(25 балів, приблизно 30 хвилин)

Nmap повідомляє, що порт відкритий. Ручна взаємодія показує, що насправді робить сервіс. У цій частині ви взаємодієте з трьома категоріями сервісів: веб, SMB, SSH, і кожна дасть різний тип свідчення. Мета, не просто "я підключився", а структурований перелік з відмінностями, які можна використати у Частині 3.

Завдання 2.1 — Перелік веб-сервісу (12 балів)

Виконайте щонайменше три різні типи взаємодії з веб-сервером на порту 80. Перше: ручний GET-запит через Netcat (`nc <target> 80`, потім `GET / HTTP/1.0` та два Enter). Зафіксуйте повні заголовки відповіді, особливо рядок `Server`. Друге: запустіть Nikto проти веб-сервера і збережіть вивід. Третє: проведіть перелік директорій інструментом `dirb` або `gobuster` з одним зі стандартних словників у Kali (`/usr/share/wordlists/dirb/common.txt` підходить як стартова точка).

Окрема увага тому, що ця ціль може поводитися інакше, якщо звертатися до неї не за IP, а за ім'ям хоста. Подивіться на заголовки відповіді й головну сторінку уважно, чи є там згадка про конкретний `hostname`? Якщо так, додайте відповідний запис у `/etc/hosts` на Kali і повторіть веб-перевірку через ім'я. Це стандартна техніка перевірки віртуальних хостів; якщо ви її пропустите, частина вмісту залишиться прихованою.

Результат, структурований підрозділ звіту: версії веб-сервера та модулів з одного рядка `Server`, список виявлених директорій і сторінок з коротким поясненням кожної, і список будь-яких CMS-подібних `endpoint`'ів, які ви зустріли (`admin`-панелі, `login`-сторінки, `index`-файли специфічних движків). Не намагайтеся вгадувати паролі; просто фіксуйте, що існує.

Завдання 2.2 — SMB та SSH (13 балів)

Перевірте, чи працюють на цілі SMB (порти 139, 445) і SSH (порт 22). Для SMB використайте щонайменше два методи: `smbclient -L` з `null`-сесією та `enum4linux -a`. Зафіксуйте що бачите: доступні ресурси, користувачі, версія Samba. Якщо жоден із методів не повертає версію напряду, зафіксуйте це явно. Відсутність інформації також є даними.

Для SSH виконайте банер-граббінг через `nc` та `Nmap` з параметром `-sV` на порту 22. Порівняйте рядки версій. Зверніть увагу на версію OpenSSH — вона підкаже вам епоху системи і дозволить звузити перелік потенційно релевантних CVE у частині 3.

У цьому завданні очікувана невдача: принаймні один із методів перелічення, ймовірно, поверне менше, ніж ви сподівалися, або взагалі нічого. Опишіть цю невдачу. Що ви пробували далі? Чому ви вирішили рухатися далі, а не продовжувати? Це документування рішення про час у реальному пентесті: найдорожчим ресурсом є не інструмент, а час.

Частина 3: Ідентифікація CVE та карта вразливостей

(25 балів, приблизно 25 хвилин)

Ви зібрали факти. Тепер час їх зіставити з відомими вразливостями. Це найважливіший крок у пентест-методології та найчастіше саме тут починається головна розбіжність між досвідченими аналітиками й початківцями: досвідчений не лише знаходить CVE, а й розуміє, чи застосовна вона у цьому конкретному контексті.

Завдання 3.1 — Автоматичне сканування вразливостей (10 балів)

Запустіть Nmap з прапором `--script vuln` проти цілі. Запустіть Nikto окремо, якщо не зробили цього у частині 2. Подивіться на результати як на набір підказок, а не як на істину. Автоматичні сканери мають високий рівень false positives, особливо на старих системах. Ваше завдання — вибрати з виводу три найбільш вартіх уваги знахідки від кожного інструмента і коротко пояснити (1–2 речення для кожної), чому саме вона привернула вашу увагу.

Документуйте і хибні спрацювання. Якщо сканер повідомив про вразливість, а ваш власний доказ з частини 2 їй суперечить, відзначте це. Наприклад, якщо Nikto скаржиться на модуль, якого ви не бачили у банері сервера.

Завдання 3.2 — Карта вразливостей (15 балів)

Побудуйте таблицю щонайменше з 5 CVE, що охоплюють щонайменше 3 різні сервіси. Обов'язкові стовпці: CVE-ID, сервіс і версія, тип уразливості (RCE, SQLi, auth bypass, information disclosure тощо), CVSS-бал, наявність публічного експлойта з джерелом (Exploit-DB, Metasploit, GitHub), доавтентифікаційний доступ (так/ні), надійність експлойта (стабільна, нестабільна, невідомо).

Kioptrix 1.2 відносно добре задокументована машина у пентест-спільноті. Це означає, що ви легко знайдете CVE, якщо чесно виконаєте частину 2. Це також означає, що спокуса скопіювати чужий список є великою. Ваша таблиця має бути обґрунтована власними доказами з частин 1 і 2. Для кожної CVE у правому стовпці додайте посилання на конкретний рядок ваших попередніх висновків, який підтверджує наявність саме цієї версії сервісу.

Не включайте CVE, яку ви не можете підтвердити власними доказами. Якщо єдине виправдання "так написав Exploit-DB", це слабко. Записи без локального доказу отримують половину балів.

Частина 4: Ранжування векторів і обґрунтування плану атаки

(25 балів, приблизно 25 хвилин)

Цю частину неможливо пройти, просто запустивши ще один сканер. Тут оцінюється ваше професійне судження. У реальних пентест-звітах саме розділ ранжування векторів читає керівництво клієнта, і саме за ним вирішується, чи ви повернетеся на наступну фазу проекту.

Завдання 4.1 — Таблиця ранжування (10 балів)

Із CVE-таблиці Частини 3 виберіть три найбільш перспективні вектори атаки. Перспективний не означає "з найвищим CVSS". Перспективний означає: висока впевненість, що спрацює у цьому середовищі, низькі входові вимоги, високий потенційний вплив, надійний публічний експлойт. Заповніть таблицю за наступним шаблоном. Бал це сума з трьох стовпців оцінки (впевненість, складність, вплив), де кожен вимірюється від 1 до 5.

Ранг	Вектор (сервіс / CVE)	Впевненість	Складність	Вплив	Бал
1	...	Висока / Середня / Низька	Тривіальна / Помірна / Важка	RCE / Доступ до даних / DoS	.../15
2	...	...	...	...	.../15
3	...	...	...	...	.../15

Показуючи свою шкалу бальної оцінки явно, ви демонструєте, що ваше судження відтворюване, а не довільне. Так працюють усі серйозні методики оцінки ризиків.

Завдання 4.2 — Обґрунтування кожного вектора (10 балів)

Для кожного з трьох векторів напишіть абзац (4–6 речень) за такою структурою. Перше речення : чому саме цей вектор перший/другий/третій у вашому ранжуванні (не сам факт високого CVSS, а саме позиція відносно інших). Друге, які конкретні докази з ваших Частин 1–2 підтверджують, що вектор застосовний до саме цієї цілі. Третє — які докази у вас відсутні і роблять вашу впевненість меншою, ніж 100%. Четверте, які ще кроки розвідки ви б провели, якби мали ще одну годину перед експлуатацією.

Цей підпункт оцінюється найсуворіше на ознаку копіювання. Три студенти, які знайшли ті самі три CVE, повинні написати три різні обґрунтування, оскільки їхня конкретна розвідка в частинах 1–2 відрізняється. Якщо ваш абзац можна підставити у звіт іншого студента без змін, це знак, що ви не спиралися на свої докази.

Завдання 4.3 — Очікуваний результат експлуатації без експлуатації (5 балів)

Для вектора ранг-1 напишіть абзац (3–5 речень) про те, що саме станеться, якщо експлоїт спрацює. Який рівень доступу ви отримаєте: користувацький shell чи одразу root? Який буде початковий shell : reverse, bind, interactive? Які наступні кроки ви плануєте виконати протягом перших 5 хвилин після отримання доступу (перевірити чутливі файли, перерахувати користувачів, знайти ознаки попередніх зломів)? Це прогноз, а не звіт; формулюйте у майбутньому часі.

Ця вправа важлива тому, що в реальному пентесті керівництво клієнта інколи зупиняє вас саме тут і приймає рішення на основі прогнозу: "якщо такий-то експлоїт спрацює, отримаємо root прямо зі shell у Apache, а далі очікуємо відкритий доступ до БД клієнтів". Ваш прогноз, частина обґрунтування розширення score проекту.

Важливі примітки

Kioptrix Level 1.2 це VM середини 2000-х на базі старого дистрибутива Linux. Якщо VirtualBox має проблеми з мережею, спробуйте видалити та повторно додати мережевий адаптер. Якщо

машина не відображається у netdiscover, перемкніть режим Promiscuous Mode у налаштуваннях адаптера на "Allow All".

Деяка частина веб-функціоналу цілі доступна лише через коректне hostname-звернення. Якщо ви переглядаєте головну сторінку лише за IP і вона здається порожньою або показує дивні посилання, саме це і є ознакою. Вивчіть заголовки та вміст сторінки на предмет hostname і додайте запис до /etc/hosts.

Деякі CVE, які ви знайдете у публічних базах, можуть бути неактуальними саме для цієї версії сервісу. Автоматичні сканери часто повідомляють про CVE за приблизним збігом версії, тоді як реальна версія на цілі не потрапляє у вразливий діапазон. Це нормально; документуйте такі знахідки як "потенційно хибні спрацьовування" у Частині 3, а не викидайте їх без пояснення.

Вся робота виконується у вашому ізольованому Host-Only середовищі. Не скануйте машини за межами VirtualBox. Див. Розділ 6 силабусу щодо політики використання AI-інструментів та академічної доброчесності.

Що здавати

Єдиний звіт у форматі DOCX, що містить усі завдання, скріншоти, таблиці та аналіз. Назвіть файл Lab6_Прізвище_Група.docx. Здайте звіт до дедлайну.

У звіті очікуються: таблиця сервісів з Частини 1, скріншоти ручних запитів і виводу інструментів з Частини 2, CVE-таблиця з Частини 3, таблиця ранжування та 3 обґрунтовані абзаци з Частини 4, прогноз результату експлуатації. Загальний обсяг власного тексту (не вивід інструментів і не таблиці) орієнтовно 1500–2000 слів.

Додаток А (необов'язковий, не оцінюється)

Верифікація ОДНОГО вектора для студентів, які завершили основну роботу

Цей додаток існує для тих, хто закінчив усі чотири частини і хоче перевірити своє ранжування на практиці. Він не впливає на оцінку. Робота у Додатку А не замінює і не компенсує невиконану основну роботу. Якщо ви не здали Частини 1–4 на прохідному рівні, цей додаток буде проігноровано.

Обмеження додатка. Ви можете виконувати експлуатацію виключно одного вектора, а саме того, який ви поставили на перше місце у своєму ранжуванні. Не двох і не всіх трьох. Мета — перевірити, чи ваше судження було правильним, а не зібрати колекцію shell-ів. Якщо експлойт не спрацьовує, це цінніший результат, ніж якщо він спрацьовує. Задokumentуйте, що саме пішло не так, і як би ви переглянули ранжування.

Обсяг документації для додатка складає щонайменше один абзац про те, як пройшла спроба експлуатації (приблизно 150–250 слів), з одним скріншотом на підтвердження результату (успіху чи невдачі). Якщо ви отримали shell, покажіть вивід whoami, id, uname -a. Не витрачайте час на пост-

експлуатаційні дії; ціль додатка це верифікація вашої власної прогнозової моделі, не демонстрація пост-експлуатації.

Результат додатка А ніяк не переноситься у Частина 4. Навіть якщо ви фактично отримали root, ваші обґрунтування у Чащині 4 оцінюються за якістю аргументації на час подання, а не за тим, що вдалося потім. Хороше обґрунтування, яке виявилось хибним, коштує більше, ніж випадкова перемога без аргументів.